

Ataques de Inyección SQL

Base de Datos Seguras
Clase universitaria

Objetivos

- • Comprender SQL Injection
- Identificar riesgos
- Aplicar mitigaciones

¿Qué es SQL Injection?

- Manipulación de consultas SQL mediante entradas no validadas.
Impacto: robo, modificación y eliminación de datos.

Tipos

- • UNION-based
- Error-based
- Blind
- Time-based
- Out-of-band

Ejemplo vulnerable

- Consulta: `SELECT * FROM usuarios WHERE usuario=[entrada]
AND clave=[entrada]`
Ejemplo de ataque: `' OR '1'='1`

Prevención

- Consultas parametrizadas
- Validación de entradas
- Principio de mínimo privilegio
- WAF
- Auditoría

Laboratorio

- 1. Crear BD de prueba
- 2. Demostrar consulta vulnerable
- 3. Corregir con parámetros
- 4. Analizar registros

Evaluación

- Explique qué es SQLi y proponga tres medidas de mitigación.

Conclusiones

- La seguridad depende del desarrollo seguro, controles y monitoreo.